YOUR GOALS OUR PRIORITY

FINANCEFIRST

CREDIT UNION

Incident Report

Incident Type: Incidence Response Action Plan

Report Version: 1.0

Report Date: 12-December-2025

Prepared By: Incidence Response Manager

Table of Contents

1. Executive Summary.....2
2. Evidence Preservation.....3
3. Containment.....4
4. Eradication And Recovery.....5
5. Inject 3.1 and 3.2).....6
6. Executive Briefing.....7
7. Post Incident Activity.....8
8. Recommendations.....9
9. Key Metrics For Improvement.....10

1. Executive Summary

NIST SP 800-61r3 (Section 3.1, Page 21):

"The incident response life cycle includes the following phases: *Preparation*; *Detection and Analysis*; *Containment, Eradication, and Recovery*; and *Post-Incident Activity*." It further adds that "Although this document presents the phases linearly, in reality, incident response is not strictly linear. Findings from one phase may cause a reversion to a previous phase." Meaning it is not a straitjacket action, flexibility is needed. This document will therefore provide a detailed explanation of the action plan for the finance mentioned above first ransomware attack.

2. PHASE 1: DETECTION AND ANALYSIS

Initial Assessment and Triage

The first priority was confirming whether the alerts were genuine or a false alarm. This included reviewing system notifications, checking user reports of inaccessible files, and carrying out quick triage tasks:

- Confirming encryption on multiple servers
- Reviewing the ransom note
- Checking the timing and spread of abnormal file activity
- Examining logs for signs of lateral movement
- Determining immediate business impact (email outage, shared drive inaccessibility, etc.)

2. EVIDENCE PRESERVATION

To maintain a defensible forensic record, the IT team was instructed not to reboot any systems. The following steps were taken:

- Memory dumps collected from affected servers
- Firewall, domain controller, and endpoint logs preserved
- Chain-of-custody initiated from the first minute

This ensured that no critical evidence was lost and that legal and regulatory reviews would have complete documentation.

SCOPE DETERMINATION

Systems were categorized into:

Affected, Potentially affected, and Unaffected.

Findings included:

- 8 file servers → encrypted
- Email system → encrypted
- Primary database → encrypted
- Backup server → encrypted
- Core banking (AS/400), online/mobile banking, and ATMs → unaffected

This was crucial because it allowed core member services to continue.

SEVERITY CLASSIFICATION

The incident was classified as critical due to:

- Exposure of personal member data
- Major operational disruption
- Possible data exfiltration
- Severe regulatory and reputational risks
- Clear threat of data publication

PHASE 2: CONTAINMENT

Short-Term Containment

Immediate actions were taken to stop the spread:

- Isolation of infected servers
- Blocking command-and-control IP addresses
- Disabling compromised admin accounts
- Emergency password resets
- Quarantining affected workstations
- Disconnecting the backup server

Long-Term Containment

After stabilizing the situation, deeper containment began:

- Deploying endpoint detection tools to uncover remaining backdoors
- Temporary network segmentation
- Disabling outdated protocols (e.g., SMBv1, open RDP)
- A complete privileged-account credential reset

Business Continuity Measures

Because the financial sector cannot shut down completely:

- Branches operated via the isolated core banking platform
- A manual loan-processing queue was activated
- Backup communication channels were created
- Staff used fallback, paper-based procedures where needed

Engagement of External Support

To ensure a professional, defensible response, the following were engaged:

- A forensic investigation firm
- Legal counsel specializing in cybersecurity
- Cyber-insurance representatives
- Ransom negotiation experts (for assessment, not decision-making)

PHASE 3: ERADICATION AND RECOVERY

Eradication Steps

- Removing all ransomware files, scripts, and persistence mechanisms
- Disabling/deleting compromised user accounts
- Rebuilding heavily damaged systems from clean, trusted images
- Additional screening for hidden tools, backdoors, or dormant malware

Recovery Approach

Systems were restored based on business priority:

1. Core banking
2. Email environment
3. File servers
4. Workstations

Data was restored from verified offline/immutable backups. Systems were brought online in controlled batches to avoid re-infection.

Validation & Testing

Before full restoration:

- Malware scans and integrity checks were performed
- Recovered data was tested for corruption
- A small pilot group validated system functionality
- Only after stable results were confirmed were all users brought back online

Return to Normal Operations

Once stable:

- Temporary workarounds were removed
- Normal business processes were restored
- Monitoring systems and logs were re-enabled
- Leadership received confirmation that all critical services were operational

INJECT 3.1 – RECOVERY DECISION

Recommended Strategy: Hybrid Approach (Option D)
Key Reasons:

- Fastest restoration (within 48 hours) to prevent member loss.
- Parallel rebuild provides long-term security.
- Balances cost, risk, and operational continuity.
- Prevents daily revenue loss and protects major accounts.

Implementation :

1. Pay ransom and decrypt critical systems under strict monitoring.
2. Begin full clean network rebuild simultaneously.
3. Migrate operations to new infrastructure within 14–21 days.
4. Maintain communication with leadership, staff, members, and regulators.

INJECT 3.2 – COMPLICATION AND RESPONSE

Crisis Communication:

- Public statement acknowledging incident and ongoing investigations.
- Immediate member notifications with credit monitoring.
- Internal staff briefing to ensure consistent messaging.
- Talking points for executives and call centers.

Damage Control:

- Free credit monitoring, fraud alerts, dedicated hotline.
- CEO-led press briefing, transparent daily updates.
- Member retention initiatives (fee waivers, direct outreach).
- Proactive regulatory engagement.
-

Ransom Reconsideration:

- Recommendation: Do NOT pay.
- Attackers already leaked data; no guarantee payment stops further leaks.
- Funds better used for member support and security improvements.

Legal & Regulatory:

- Notify NCUA, state regulators, and Attorneys General.
- Coordinate with FBI/Secret Service.
- Prepare for class action suits.
- File cyber insurance claims for recovery costs.

EXECUTIVE BRIEFING

To the Board of Directors

Current Situation:
We are 24 hours into a major ransomware incident. Systems remain isolated, forensics is finding multiple backdoors, and operations are running at reduced capacity. Member pressure is rising and three major commercial clients have said they will leave if full services are not restored within one week.

Our Options in Simple Terms
Option A – Pay Ransom Only
Fastest option but high risk of reinfection and no guaranteed clean data.

Option B – Restore 45-Day-Old Backups
Cheapest but extremely damaging due to major data loss and slow recovery.

Option C – Full Network Rebuild
Strongest long-term security but far too slow to protect the business.

Option D – Hybrid Approach (Recommended)
Restore service fast using decryption keys and simultaneously build a clean, secure network in the background.

Why Option D is recommended
Gets critical systems online in 48 hours fast enough to keep members and commercial clients from leaving.
Gives us a clean, rebuilt environment for long-term security.
Reduces financial and reputational risk.
Aligns with regulatory expectations.

Expected Timeline
48 hours: Services partially restored
7 days: Systems stabilized
14–21 days: Complete migration to new, secure infrastructure

Expected Cost
Direct cost: **$2.5M**
Much lower long-term losses than continued downtime or member attrition.

Long-Term Benefits
Stronger cybersecurity posture
Modern infrastructure
Restored confidence from members and regulators
Lower risk of future ransomware attacks

PHASE 4: POST-INCIDENT ACTIVITY (48-72 HOURS)

1. ROOT CAUSE ANALYSIS (FIVE WHYs)

Problem: How did the ransomware succeed?

1. Because a phishing email was opened, allowing malware execution.
2. Because basic email security didn't block the malicious attachment.
3. Because security awareness training wasn't strong or frequent enough.
4. Because the attacker moved laterally for weeks without detection due to weak segmentation and poor alerting.
5. Because the security program was still developing and the IR plan had never been tested.

Core Root Causes

- Weak technical controls (email filtering, SIEM alerts, segmentation, PAM)
- Insufficient employee awareness
- Lack of continuous monitoring
- Backup server not properly isolated
- Incident Response Plan not validated

2. LESSONS LEARNED

What Worked Well

- Core banking remained isolated and operational
- Cloud services stayed online
- Rapid containment prevented further spread
- Leadership provided quick approvals and support
- Forensics gave deep visibility
- Documentation was thorough and useful for compliance

What Did Not Work Well

- Weak phishing defense
- Poor SIEM alert coverage
- Lack of privileged access governance
- Flat network architecture
- Backup server vulnerable
- IR plan unclear, untested
- No structured crisis communication plan

3. RECOMMENDATIONS

A. People

- Quarterly phishing simulations
- Mandatory annual cybersecurity training
- Targeted training for high-risk teams (Finance, HR, Executives)
- Skill development and certification for CSIRT
- Crisis communication training for leadership

B. Process

- Update and clarify IR roles and escalation paths
- Integrate legal/breach notification procedures
- Create ransomware-specific playbooks
- Strengthen BCP/DR and test regularly
- Implement formal vulnerability management, patching, and backup governance

C. Technology

- Deploy PAM and enforce MFA everywhere
- Implement endpoint detection (EDR/XDR)
- Redesign the network with effective segmentation
- Establish immutable, offline backups
- Improve SIEM rules (PowerShell, lateral movement, exfiltration alerts)
- Begin moving toward zero-trust architecture

4. KEY METRICS FOR IMPROVEMENT

Incident Response Performance

- MTTD: < 1 hour
- MTTR (response): < 2 hours
- MTTC: < 4 hours
- MTTR (recovery): 48–72 hours for critical systems

Training and Awareness

- Phishing failure rate: < 5%
- Training completion: 100%
- Regular IR exercises

Security Controls

- 100% endpoint EDR coverage
- 100% privileged accounts under PAM
- 99% backup success rate, tested quarterly

Condensed High-Level Summary

Attack Path

- Phishing → TrickBot → credential theft
- Lateral movement via SMB/RDP/PowerShell
- Domain takeover → data exfiltration → mass encryption

Top Recommendations

- Strengthen email and phishing defenses
- Enforce PAM and MFA
- Improve SIEM visibility
- Redesign the network with segmentation
- Deploy immutable/offline backups
- Test IR and BCP/DR annually
- Tighten legal review and communication processes